# SIMATS ENGINEERING

# CSA6303- Threat Intelligence and Network Security

# A1-Threat Intelligence Report

Assessment Questions

| | | | |
|---|---|---|---|
| **Subject** | Threat Intelligence | **Total Marks** | 50 |
| **Questions** | 10 (all compulsory) | **Marks per Question** | 5 |
| **Reg.No** | 192311129 | **Name** | Narra Harshith |
| **Faculty** | Dr.V.Parthipan | **Slot** | A |

*Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.*

***Code of Conduct:***

*I* N.Harshith (192311129) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

*N.Harshith*

**Signature of Student**

## Questions

## Q1. Malware

**Malware (Malicious Software)** is any software intentionally designed to harm, exploit, disrupt, or gain unauthorized access to computer systems, networks, or data.

**Four Types of Malware**

| Type | How it Spreads | Impact on Victim |
|---|---|---|
| **Virus** | Attaches itself to legitimate files or programs and spreads when the infected file is executed. | Corrupts files, damages data, and slows system performance. |
| **Worm** | Self-replicates across networks without requiring user action. | Consumes bandwidth and resources, causing network disruption. |
| **Trojan Horse** | Disguises itself as legitimate software and tricks users into installing it. | Creates backdoors, steals information, or gives attackers remote access. |
| **Ransomware** | Delivered through phishing emails, malicious downloads, or exploit kits. | Encrypts files and demands payment for decryption. |
| **Spyware** | Installed secretly through malicious software or unsafe downloads. | Monitors user activities and steals sensitive information such as passwords and banking details. |

## Q2. Phishing

### How a Phishing Attack is Carried Out

1. The attacker creates a fake email, website, or message that appears legitimate.
2. The message contains a malicious link or attachment.
3. The victim clicks the link or opens the file.
4. The victim is redirected to a fake website or unknowingly downloads malware.
5. The attacker steals credentials, financial information, or gains unauthorized access.

### Types of Phishing

| Type | Description |
|---|---|
| **Spear Phishing** | A targeted phishing attack aimed at a specific individual or organization using personalized information. |
| **Whaling** | Targets high-profile individuals such as CEOs, executives, or senior managers. |
| **Vishing (Voice Phishing)** | Uses phone calls or voice messages to trick victims into revealing sensitive information. |

### Measures to Reduce Phishing Risk

1. Conduct regular security awareness training for employees.
2. Enable Multi-Factor Authentication (MFA).
3. Use email filtering and anti-phishing solutions.

## Q3. DoS and DDoS

### Difference Between DoS and DDoS

| Feature | DoS | DDoS |
|---|---|---|
| Number of Attack Sources | Single system | Multiple compromised systems (botnet) |
| Scale | Smaller | Much larger |
| Detection | Easier | More difficult |
| Impact | Limited | Severe service disruption |

### SYN Flood Attack

A SYN Flood exploits the TCP three-way handshake:

1. Attacker sends numerous SYN packets to a server.
2. Server responds with SYN-ACK packets.
3. Attacker never sends the final ACK.
4. The server keeps half-open connections in memory.
5. Resources become exhausted, preventing legitimate users from connecting.

### Mitigation Techniques

1. **SYN Cookies** to validate connection requests before allocating resources.
2. **Rate Limiting** to restrict excessive connection requests from a source.

Other methods include CDNs, DDoS scrubbing services, and blackhole routing.

## Q4. Man-in-the-Middle Attacks

A **Man-in-the-Middle (MITM) attack** occurs when an attacker secretly intercepts and possibly alters communications between two parties without their knowledge.

### Techniques Used

### 1. ARP Poisoning

- The attacker sends forged ARP messages on a local network.
- Victims associate the attacker's MAC address with the gateway IP address.
- The attacker can intercept network traffic.

### 2. Rogue Wi-Fi Access Point

- The attacker creates a fake Wi-Fi hotspot that appears legitimate.
- Victims connect to the rogue network.
- The attacker captures data transmitted through the network.

### How Encryption Helps

- **TLS/HTTPS encryption** prevents attackers from reading intercepted data.
- **HSTS** forces secure HTTPS connections.
- **Certificate validation** helps ensure communication with legitimate servers.
- **VPNs** encrypt data across untrusted networks.

## Q5. Spoofing and Sniffing

### Comparison

| Spoofing | Sniffing |
|---|---|
| Involves impersonating another device or identity. | Involves capturing and monitoring network traffic. |
| Active attack technique. | Usually passive attack technique. |
| Used to deceive systems. | Used to observe or collect data. |

### IP Spoofing :

IP spoofing occurs when an attacker changes the source IP address in packets.

**Example:** An attacker sends packets pretending to come from a trusted server to bypass access controls.

**ARP Spoofing :**

ARP spoofing involves sending fake ARP messages to associate the attacker's MAC address with another device's IP address.

**Example:** An attacker associates their MAC address with the default gateway's IP to intercept network traffic.

**Packet Sniffers (Wireshark)**

**Malicious Use**

- Capturing usernames and passwords.
- Monitoring sensitive communications.

**Legitimate Use**

- Network troubleshooting.
- Performance monitoring and security analysis.

**Countermeasure**

Use **encryption (HTTPS, VPNs, SSH)** to protect data from packet sniffing.

## Q6. Vulnerability Assessment

A **Vulnerability Assessment (VA)** is a systematic process used to identify, evaluate, and prioritize security weaknesses in systems, applications, and networks.

**Main Phases :**

**1.Asset Discovery :** Identify systems, applications, and network devices.

**2.Vulnerability Scanning :** Use automated tools to discover vulnerabilities.

**3.Analysis and Prioritization :** Assess severity and business impact.

**4. Reporting :** Document findings and recommendations.

**5.Remediation and Verification :**Apply fixes and validate that vulnerabilities are resolved.

**Vulnerability Assessment vs Penetration Testing**

| Vulnerability Assessment | Penetration Testing |
|---|---|
| Identifies vulnerabilities. | Exploits vulnerabilities. |
| Broad coverage. | Deep and targeted testing. |
| Automated and continuous. | Mostly manual and goal-oriented. |
| Provides list of weaknesses. | Demonstrates actual impact. |

**Common Tools**

1. Nessus
2. OpenVAS (Greenbone)

## Q7. Vulnerability Scoring

**What is CVE?**

**CVE (Common Vulnerabilities and Exposures)** is a standardized identifier assigned to publicly disclosed cybersecurity vulnerabilities.

Example: **CVE-2021-44228 (Log4Shell)**.

**What is CVSS?**

**CVSS (Common Vulnerability Scoring System)** is a framework used to measure the severity of vulnerabilities on a scale from **0.0 to 10.0**.

**CVSS Severity Ratings**

| Score | Severity |
|---|---|
| 0.0 | None |
| 0.1 - 3.9 | Low |
| 4.0 - 6.9 | Medium |
| 7.0 - 8.9 | High |
| 9.0 - 10.0 | Critical |

**Role in Prioritization**

CVSS helps organizations:

- Rank vulnerabilities by severity.
- Focus first on high-risk issues.
- Allocate resources effectively.

### Why High CVSS Alone Is Not Enough

Organizations should also consider:

- Asset criticality.
- Availability of exploits.
- Exposure to the internet.
- Business impact.
- Existing security controls.

## Q8. Threat Data Sources and OSINT

### Main Sources of Threat Data

#### 1. Internal Sources

- Security logs
- SIEM alerts
- Incident reports

#### 2. External Sources

- Government advisories
- Industry reports
- CERT notifications

#### 3. Open-Source Sources

- Public databases
- Security blogs
- Research publications

#### 4. Commercial Sources

- Paid threat intelligence providers
- Vendor-specific threat feeds

### OSINT Definition

**Open-Source Intelligence (OSINT)** is the process of collecting and analyzing information from publicly available sources for security investigations and threat intelligence.

### OSINT Sources/Tools

#### 1. Shodan

Search engine that discovers internet-connected devices.

#### 2. VirusTotal

Analyzes files and URLs for malware and malicious activity.

#### 3. WHOIS

Provides domain registration and ownership information.

Other examples: social media platforms, GitHub, dark web monitoring services.

## Q9. Indicators of Compromise (IoCs)

**Indicators of Compromise (IoCs)** are forensic artifacts or observable signs that suggest a system or network may have been compromised by malicious activity.

### Types and Examples

#### A. Network-Based IoCs

1. Communication with known malicious IP addresses.
2. Connections to suspicious domains.

#### B. Host-Based IoCs

1. Unauthorized user account creation.
2. Unexpected processes or services running.

#### C. File-Based IoCs

1. Malicious file hashes (MD5, SHA-256).
2. Suspicious filenames or altered system files.

### Use During Incident Response

Security teams use IoCs to:

- Detect compromised systems.
- Search for similar infections.
- Investigate attacker activity.
- Contain and eradicate threats.
- Monitor for reinfection.

## Q10. Threat Feeds

A **Threat Intelligence Feed** is a continuous stream of cybersecurity information that provides data about known threats, malicious IPs, domains, malware signatures, vulnerabilities, and attack techniques.

### Common Formats and Sharing Standards

### STIX (Structured Threat Information eXpression)

- Standardized language for representing threat intelligence.

### TAXII (Trusted Automated eXchange of Indicator Information)

- Protocol for sharing threat intelligence between organizations.

### Advantages

1. Provides early warning of emerging threats.
2. Improves threat detection and response capabilities.

### Limitations

1. Can generate false positives.
2. Large volumes of data require filtering and analysis.

### Example Threat Feeds

1. AlienVault OTX
2. abuse.ch